Compliance Auditing Basics

DeRexi: Policy Pilot | Aurum Capital Bank (fictional demonstration client)
Consolidated assessment and remediation verification • 5 November 2026

EXECUTIVE ASSESSMENT

Three security controls were audited against defined expectations. The 3 November baseline revealed significant gaps; the 5 November retest demonstrates correction of the original check failures in controlled, explicitly secured test profiles. This is application-layer verification in test environments, not a production security certification.

15 / 15	26 / 26	55 / 55
C-01 • RBAC	C-02 • Input validation	C-03 • Feed integrity

Assessment disposition: All 96 original control checks passed in the current test profiles (15 + 26 + 55). Separate testing also reports 40 RBAC foundation checks, 24 JWT foundation checks, 32 secured API/demo checks, 28 workflow regression checks, 22 integrity regression checks, 97 offline Pulse checks, and 14 passing browser workflows. Counts represent different suites and are not treated as unique independent controls.

Material limitations: The standard main:app entry point remains unguarded; production sign-in, live Supabase testing and deployment were not completed. Live regulatory feed retesting was blocked by proxy 403. One browser workflow was blocked by the previously missing Messages route, and four incident guidance checks remain failing.

REPORT PURPOSE

This document satisfies the Assignment 3 audit deliverables through (1) a scoped plan, (2) collection standards and evidence for three controls, (3) gap analysis and assessment results, and (4) a prioritized corrective-action and follow-up plan. Actual implementation status is described separately from proposed operational milestones.

Evidence basis: Codex security-hardening verification dated 5 November 2026 and the original C-03 audit of 3 November 2026. Detailed test logs are referenced by file path; they were not attached to this report.

Scope, methodology & resources

Audit objective. Determine whether DeRexi enforces authenticated role-appropriate access (C-01), rejects unsafe or invalid application inputs (C-02), and accurately validates the origin and presentation of regulatory feed data (C-03).

Area	In scope	Excluded / limitation
C-01 · Access control	JWT verification, role permissions, object ownership, denial before write, local persona switching	Live Supabase identity provisioning; production deployment
C-02 · Validation	Pydantic/handler validation, relationships, error responses, rejected writes	Untested legacy production database contents
C-03 · Pulse	Official-source registry, hostname/redirect checks, normalization, XSS, cache	Independent legal authenticity of publications; live feeds blocked on retest

Audit methodology

- Define expected outcomes and control owners using existing requirements and NIST CSF 2.0 / SP 800-53 control concepts.
- Inspect application code and previously executed tests, preserving original evidence and test definitions.
- Execute isolated negative and positive checks; use signed local identities, disposable SQLite with foreign keys, and Chromium where applicable.
- Compare actual behavior with expected outcomes and record PASS, FAIL, BLOCKED, or NOT RUN.
- Assess gaps, recommend actions, and establish a follow-up test and evidence protocol.

Resources and independence

Resources: Python/FastAPI, SQLAlchemy, existing virtual environment, scripted test suites, synthetic JWTs and fixtures, disposable relational SQLite, headless Chromium, preserved JSON/log evidence, and source inspection. Owner: Security / Technical Lead. Review: a separate reviewer is recommended where feasible; this capstone assessment does not demonstrate independent external assurance.

Audit timeline

Stage	Recorded / planned activity
03 Nov · Baseline	Assess C-01/C-02; run C-03 tests; preserve failures and original evidence.
05 Nov · Corrective retest	Run integrated secured/test profiles, workflow regressions, browser test and security check suites.
Next review · Proposed	Verify production-entry-point migration plan, original roster demo, live-feed access and incident workflow fixes.
Before any deployment · Proposed	Repeat full control suite with approved identities and deployment controls; authorize release only after closure.

Three-control evidence register

Control	Collection approach	Primary evidence / outcome
C-01 Authentication & RBAC	JWT and principal tests, direct API calls, cross-user/role authorization attempts, no-write assertions.	Original 0/15; secured/test profile 15/15. Stage 1 permission suite 40 passed; JWT foundation 24 passed.
C-02 Input validation & safe errors	Invalid types and IDs, empty/long inputs, missing references, workflow transactions, persisted state checks.	Original 16/26; retest 26/26. Additional validation/workflow suite 28 passed.
C-03 Regulatory source integrity	Source fixtures, hostname checks, redirect validation, safe normalization, live feed prior evidence, hostile Chromium render.	Original 54/55; retest 55/55. Pulse offline suite 97 passed; current live feeds blocked.

Evidence handling standard

For each test retain its control ID, test ID, expected and actual outcome, timestamp, status, executed command, environment, sanitized output path and any known limitations. Preserve original baseline artifacts unchanged, identify test revisions, and keep runnable test scripts with the repository. Never include credentials, tokens, connection strings, employee-private messages or live customer information in screenshots or reports.

Selected source artifacts

November 5 consolidated verification
docs/compliance/evidence/verification_2026-11-05T170344061112Z/verification_results.json

November 5 Chromium results
docs/compliance/evidence/browser_resume_2026-11-05_EF61bG/browser_results.json

Original C-03 audit detail
docs/compliance/assignment3_c03_audit_results.md

Original C-03 machine-readable results
docs/compliance/evidence/c03_audit_results.json

November 3 C-03 console audit
docs/compliance/evidence/c03_audit_checks_2026-11-03.txt

Prior offline + live Pulse checks
docs/compliance/evidence/c03_pulse_suite_offline_2026-11-03.txt; c03_pulse_suite_live_2026-11-03.txt

Provenance note. The November 5 document describes test outcomes but ends at the beginning of its “Exact commands and isolation” code block. The complete commands must therefore be retrieved from the referenced runner logs before formal reproduction; this report does not invent them.

Results, gap analysis & risk

Control	3 Nov baseline	5 Nov retest	Assessment / remaining gap
C-01	0 / 15	15 / 15	Verified within explicit secured API/test profile; default main:app still unguarded.
C-02	16 / 26	26 / 26	Verified in tested shared handlers/schemas; real existing Supabase data not assessed.
C-03	54 / 55	55 / 55	Verified in synthetic/backend + fresh browser test; live fetch retest blocked.

C-01 · What improved

Codex added an explicit authenticated API assembly with verified JWT signatures/claims, server-side role resolution, route guards and object ownership. Employees receive only allowed policy, incident and thread data; policy owners manage eligible drafts; administrators approve publication under the defined matrix. The local demo uses a separate, loopback-only entry point and ephemeral data. The normal course UI has not migrated to production login, and the original roster has not been demonstrated in that path.

C-02 · What improved

Shared handlers now reject whitespace-only required values, overly long fields, coercible booleans, unsupported IDs, unrelated references, invalid patches and unexpected fields. Errors avoid technical leakage and use appropriate 4xx/5xx responses. Rejected writes were checked using disposable relational test data.

C-03 · What improved

Pulse now requires source-specific approved HTTPS hosts, checks configured feed redirects and final destinations, rejects lookalike hosts, and preserves legitimate FDIC GovDelivery bulletin paths. A new Chromium hostile-content test passed. The prior source-attribution failure C03-54 is reported as closed in tested code; current live endpoints could not be reached from Codex because the proxy returned 403.

Open findings & scope exclusions

ID / severity	Risk statement	Current disposition
R-01 · High	Unauthenticated compatibility entry point main:app remains available if improperly exposed.	Keep loopback-only; migrate to secured bootstrap before deployment.
R-02 · High	Production user mapping and approved local copy of 12 fictional identities are not provisioned.	Real sign-in/demo-data migration not verified.
R-03 · Medium	Four incident guidance tests remain failing; Messages route remains missing.	Known issues; separate product corrections and retest.
R-04 · Medium	Current live Pulse reachability not verified due to proxy 403.	Retest in a permitted environment; no proxy bypass.

Prioritized corrective-action plan

The following deadlines are proposed follow-up targets, not recorded commitments. Priority reflects impact on safe deployment and reliable demonstrations.

Priority / owner	Corrective action	Target & closure evidence
P0 · Technical Lead	Ensure any deployed entry point uses authenticated_application; prevent network exposure of main:app; establish verified Supabase subject-to-user mapping.	Before deployment. Unauthorized direct API calls denied; no unguarded route deployed.
P1 · Developer / Compliance Lead	Create approved, sanitized local roster copy preserving existing employee IDs, roles, departments and policy ownership; test full persona-switch workflow.	Next development cycle. Audited roster parity + role-switch/ownership screenshots.
P1 · Backend Lead	Restore participant-scoped Messages read route and address 4 remaining incident guidance failures without broadening permissions.	Next development cycle. Messages and incident regression suites pass.
P1 · Technical Lead	Rerun public regulatory feeds in approved network environment, confirm official FDIC GovDelivery and other source links; preserve results.	Before calling external integration operational. Live source results and source-host audit.
P2 · Independent reviewer	Review security control test changes, execute final API/UI scenarios and check release evidence for scope consistency.	Before release review. Signed test summary and open-risk disposition.

Progress-tracking method

Maintain one finding register with ID, severity, affected asset, owner, action, due date, status (Open / In Progress / Ready for Retest / Closed / Accepted Risk), evidence link, verification date and independent reviewer. Closure requires an observed passing test; a merged commit alone does not close a control finding. Review weekly during development and before any release.

Verification gates

- C-01: secured production entry point, real authorized principal mapping, all role/object checks and developer demo isolation validated.
- C-02: required positive/negative cases pass against the deployed schema and authorized backend; rejected requests cause no unwanted writes.
- C-03: source-host and renderer checks pass; official feeds are reachable and attributed correctly in the target environment.
- Product: original employee relationships, Messages and incident workflows preserved; unguarded compatibility endpoint not publicly exposed.

Final disposition & limitations

The assessment documents a full audit cycle: defined controls and evidence, baseline testing, recorded deficiencies, corrective implementation, repeat testing and prioritized follow-up. The 5 November evidence supports all original control checks passing in the explicit secured/test profiles. This is a substantial product improvement and meets the documentary intent of the Compliance Auditing Basics assignment.

It does not show that the existing course-facing application is secured in every startup mode or that real Supabase / public deployment has been verified. In particular, main:app remains unguarded, the production login path is incomplete, live regulatory feeds were blocked on retest, and the Messages/incident exceptions remain open. These are release blockers or documented limitations rather than falsely passing tests.

Applicable frameworks & interpretation

GLBA and FFIEC supervisory guidance provide the financial-services compliance context; NIST CSF 2.0 and selected NIST SP 800-53 concepts provide the cybersecurity control structure. This assessment does not certify Aurum Capital Bank, establish legal compliance, or independently authenticate the substance of agency regulations. For C-03 the underlying audit specifically maps ID.AM-04, GV.SC-07, PR.DS-02, PR.DS-06 and PR.DS-10 to observed test evidence.

Audit limitations

Testing used synthetic identities, mocked JWKS, disposable SQLite with foreign keys and a controlled browser. Production PostgreSQL/Supabase RLS, Auth users, tenant boundaries, live customer data and an external deployed runtime were not verified. The original C-03 audit's live checks were performed on November 3; November 5 live checks were blocked. Some historical browser evidence was superseded by a fresh Chromium test. Independent audit sign-off has not been provided.

Submission checklist

Rubric deliverable	Status in this report
Audit plan (scope, methods, dates, resources)	Included — Section 01
Evidence for three controls and collection standards	Included — Section 02
Control assessment, testing and gap analysis	Included — Section 03
Prioritized remediation and progress tracking	Included — Section 04

Document control: DeRexi Compliance 1 / Assignment 3 • Prepared 5 November 2026 • Status: Final coursework report with open technical release actions.